11.3 개인정보 보호 및 보안			
규 정 번 호	11.3	제 정 일	
관련 인증기준	11.3 개인정보 보호 및 보안	최근 개정일	
담 당 부 서	원무과	시 행 일	
검 토 책 임 자	병원 운영위원회	검 토 주 기	2년
승 인 책 임 자	병원장	검토 예정일	
관 련 근 거	1. 개인정보 보호법 제 29조, 제 31조, 동법 시행령 제 32조 2. 개인정보의 안정성 확보조치 기준(개인정보보호위원회고시 제2021-2호) 3. 개인정보 보호 가이드라인(의료기관편, 보건복지부,20201.2)		

▣ 목적

진료 및 모든 병원 업무처리 과정에서 처리되는 개인정보를 보호하기 위한 체계를 수립하고, 내부자의 고의나, 관리 부주의 또는 외부의 공격으로 인해 유출·변조·훼손되지 않도록 안전하게 관리·운영하기 위함이다.

▣ 용어의 정의

1. 개인정보 : 환자, 환자의 대리인, 의료인 및 직원 등 의료기관 근로자에 관한 정보로서 이름, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보(해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다.
2. 개인정보의 처리 : 개인정보의 수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정, 복구, 이용, 제공, 공개, 파기, 그 밖에 이와 유사한 행위를 말한다.
3. 개인정보의 정보주체 : 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람을 말한다.
4. 개인정보파일 : 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물을 말한다.
5. 개인정보처리자 : 업무를 목적으로 개인정보파일을 운용하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리 하는 공공기관, 법인, 단체 및 개인 등을 말한다.
6. 개인정보 보호책임자 : 개인정보처리자의 개인정보 처리에 관한 업무를 총괄해서 책임지거나 업무처리를 최종적으로 결정하는 자로서 「개인정보보호법」 제31조(개인정보 보호책임자의 지정)에 따른 지위에 해당하는 자를 말한다.
7. 개인정보 보호 및 정보시스템 보안 실무담당자(이하 “실무담당자”라 한다.) : 개인정보 보호책임자를 보좌하여 개인정보 보호업무에 대한 실무를 총괄하고 관리하는 자를 말한다.
8. 개인정보취급자 : 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 업무를 담당하는 자로서 직접 개인정보에 관한 업무를 담당하는 자와 그 밖에 업무상 필요에 의해 개인정보에 접근하여 처리하는 모든 자를 말한다.
9. 개인정보처리시스템 : 개인정보를 처리할 수 있도록 구성한 데이터베이스 시스템을 말한다.

▣ 정책

1. 개인정보 보호 및 보안에 대한 규정이 있다.
2. 개인정보 보호 및 정보시스템 보안을 관리하는 적격한 자가 있다.
3. 접근통제구역의 출입을 관리한다.
4. 정보시스템 접근통제 및 접근 권한을 관리한다.
5. 정보시스템 접속기록을 보관하고 관리한다.

▣ 지침 및 절차

1. 개인정보 보호 및 정보시스템 보안 관리 인력

가. 직원 자격 및 면허

1) 개인정보 보호책임자

가) 개인정보 보호책임자는 개인정보 보호법 시행령 제 32조에 따라 개인정보 처리 관련 업무를 담당하는 자로 '병원장' 으로 지정한다.

나) 개인정보 보호책임자는 다음 각 호의 업무를 수행한다.

(1) 개인정보 보호 계획의 수립 및 시행

(2) 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선

(3) 개인정보 처리와 관련한 불만의 처리 및 피해 구제

(4) 개인정보 유출 및 오용, 남용 방지를 위한 내부통제시스템의 구축

(5) 개인정보 보호 교육 계획의 수립 및 시행

(6) 개인정보파일의 보호 및 관리·감독

(7) 법 제30조(개인정보 처리방침의 수립 및 공개)에 따른 개인정보 처리방침 의 수립·변경 및 시행

(8) 개인정보보호 관련 자료의 관리

(9) 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기

2) 개인정보 보호 실무담당자

가) 개인정보 보호 실무담당자는 개인정보 처리 관련 업무를 담당하는 부서의 직원으로 개인정보 보호 업무를 담당하는 '보건의료정보관리사' 로 지정한다.

나) 개인정보 보호 실무담당자는 개인정보 보호책임자의 업무 수행을 보좌하며, 그 실 무를 진행한다.

3) 정보시스템 보안 실무담당자

가) 정보시스템 보안 실무담당자는 외부로부터의 침입, 접근 및 해킹 등으로부터 개인정보시스템을 보호하여 개인정보가 유출되지 않도록 하는 업무를 담당하는 부서의 직원으로 개인정보 보호 업무를 담당하는 '원무과장'으로 지정한다.

나) 기관의 개인정보시스템을 관련 법률과 기관의 개인정보보호 규정에 적합하도록 관리하는 업무를 담당한다.

나. 교육 등

1) 자격 및 면허 유지를 위한 보수교육 등을 이수하기 위해서 다음과 같이 진행한다.

가) 계획 수립 및 실시

(1) 개인정보 보호책임자, 개인정보 보호 실무 담당자, 정보시스템 보안 실무 담당자는 연 1

회 이상 개인정보보호 관련 교육을 이수 해야 한다.

(2) 개인정보취급자는 개인정보 보호 교육을 연 1회 이수한다.

나) 교육 실시 방법

(1) 집체교육 또는 온라인, 인트라넷 등 다양한 방법을 활용하여 실시할 수 있고 필요한 경우 외부 전문기관에 위탁하여 교육을 실시할 수 있다.

2. 접근통제구역의 지정 및 출입통제

가. 접근통제구역의 지정

1) 접근통제구역은 의무기록실로 한다.

나. 출입통제

1) 물리적인 접근통제를 위해 시건장치 설치와 통제구역 표찰을 부착한다.
2) 접근통제구역인 의무기록실은 통제구역 출입관리대장을 상시 비치·운용한다.
3) 인가된 사람만 출입하도록 별도의 출입증을 제공한다.
   가) 의무기록실 : 보건의료정보관리사
4) 의무기록실 출입 시에는 보건의료정보관리사에게 승인을 받아야만 하며 보건의료정보관리사와 동행하여 의무기록실에 비치해 놓은 출입관리 대장 작성 후 출입하여야 한다.

3. 정보시스템 접근통제 및 접근권한 관리

가. 접근통제

1) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위하여 방화벽(Firewall) 또는 침입방지시스템(IPS) 등 접근통제시스템을 설치하여 운영한다.
2) 바이러스와 같은 유해 소프트웨어 탐지 및 방지, 해킹프로그램 등으로 인한 침해사고가 발생하지 않도록 보안 프로그램을 설치·운영하고 자동 업데이트를 실행토록 설정한다.

나. 접근권한 관리

1) 개인정보 보호 실무담당자는 [11.1 의료정보/의무기록 관리] 규정의 [의무기록 접근권한 관리]에 따라 개별적으로 정보시스템 접근 권한을 부여하고, 총무팀 인사 담당자는 [개인정보 보호 및 보안(교육) 서약서]를 받는다.
2) 보건의료정보관리사는 모든 사용자에게 한 개의 별도 계정을 부여하고 사용자 인증을 위해 아이디/패스워드를 적용하며 의료인인 경우 전자인증을 포함한다.
3) 정보시스템 접속 사용자 계정 및 비밀번호를 타인과 공유 사용하지 않도록 한다.
4) 정보시스템 비밀번호 관리
   가) 개인정보취급자가 또는 정보주체가 생일, 주민등록번호, 전화번호 등 추측하기 쉬운 숫자나 개인관련 정보를 패스워드로 이용하지 않고 안전한 비밀번호를 설정할 수 있도록 이행 가능한 비밀번호 작성규칙을 수립하여 적용한다.
   나) 비밀번호 작성규칙은 다음과 같다.

변경주기	반기별 1회(6개월 이내)
작성규칙	- 최소 길이 8자리 이상 : 두 종류 이상의 문자로 구성한 경우 ※ 문자 종류 : 특수문자, 숫자, 알파벳 대문자와 소문자 - 최소 길이 10자리 이상 : 하나의 문자 종류로 구성한 경우 ※ 문자 종류 : 특수문자, 숫자, 알파벳 대문자와 소문자

	- 과거 사용한 비밀번호 점검

5) 접근권한

가) 인사담당자로부터 입사, 인사이동, 퇴사등 인사발령이 발생한 경우 내용을 서면으로 보건의료정보관리사는 인계받는다.

나) 인사발령 내용을 기준으로 접근권한 관리대장을 작성한 후 접근권한을 사용자 직종 및 업무 수행에 필요한 최소한의 범위로 부여한다.

다) 인사이동, 직무변경, 퇴직 시 접근권한 관리대장을 작성한 후 즉시 정보시스템 사용자들의 접근권한을 조정하거나 회수한다.

(1) 인사발령 종류에 따른 정보시스템 사용자에게 징구되는 붙임 서류는 다음과 같다.

6) 정보시스템 접근권한의 정기적 재검토 및 조치

인사발령 종류	붙임 서류
신규 입사자	- 개인정보 보호 및 보안(교육) 서약서 - ID 발급 신청서
입사, 인사이동, 퇴사 등	- 의료정보의무기록부여(변경)요청서

가) 보건의료정보관리사는 정기적(매월 1회)으로 사용자 계정의 등록·이용·삭제 및 접근권한의 부여·변경·삭제 이력을 검토하여 접근권한 과다부여, 권한부여 절차 미준수, 권한 오·남용 등 문제점을 확인한다.

나) 문제점 발견 즉시 개인정보 보호책임자에게 보고한 후 사용자계정 및 접근권한을 재부여하거나 필요 시 회수한다.

4. 의료행위와 관련된 정보시스템 접속기록의 보관 및 관리

가. 접속기록의 보관

1) 개인정보취급자가 개인정보처리시스템에 접속한 기록은 최소 6개월 이상 위·변조 및 도난, 분실되지 않도록 안전하게 보관한다.

2) 전자의무기록은 의료정보시스템의 컴퓨터 서버 및 변조 불가능한 별도의 백업 장치에 저장, 보관하며 의무기록 원본 훼손이 발생하였을 때는 즉시 복구한다.

나. 접속기록 관리

1) 접속기록의 내용은 다음과 같다.

가) 개인정보취급자 계정(ID-개인정보취급자 식별정보)

나) 접속일시

다) 접속지 정보(접속자 IP 주소)

라) 처리한 정보주체 정보

마) 수행업무(입력, 열람, 수정, 삭제, 출력 등) 등

2) 접속기록 시점은 다음과 같다.

가) 환자 개인정보의 쓰기, 수정, 삭제, 출력 시

3) 접속기록의 정기적 모니터링 및 조치

가) 정보시스템 접속기록의 정기적(반기별)으로 다음과 같이 모니터링하여 점검하고 문제점

발견 시 병원장에게 보고한 후 사용자계정 및 접근권한을 회수한다.

4) 과도한 데이터 다운로드(출력) 등 비정상적인 사용에 대한 문제점을 확인한다.
5) 권한 및 절차에 따른 개인정보의 쓰기·수정·삭제·출력을 수행하였는지 확인한다.
6) 비인가자에 의한 정보시스템 접속 여부를 확인한다.

▣ 부록 (Appendix)

1. 접근권한 관리대장

▣ 규정 개정일 [누적]

승 인 책 임 자	병 원 장	이름		서명	
승 인 일	. . .				

부록 1. 접근권한 관리대장

접근권한 관리대장

부서	성명	접근권한 변동일	접근권한 변동사항	접근권한 변동 사유
			□부여 □변경 □삭제	
			□부여 □변경 □삭제	
			□부여 □변경 □삭제	